SE Lab 5: Static Code Analysis

Field	Details
Name	Samiksha BN
SRN	PES1UG24CS413
Course	Software Engineering, Semester 5
Assigned repo (fork)	https://github.com/SamikshaBN/L5_48_gym_membership_system
Individual repo	https://github.com/SamikshaBN/SE-Labs-PES1UG24CS413

1. Introduction

1.1 Static Code Analysis

Static code analysis examines source code without executing it, to find bugs, security vulnerabilities and style violations early. Because it works on the code itself, it can inspect every path, including rarely executed ones, and it can be automated in editors and CI pipelines so problems are caught before code is merged.

1.2 The three tools used

Tool	Role	What it checks
Pylint	Strict code reviewer	Code quality and logic: unused variables and imports, mutable default arguments, bare excepts, naming conventions, missing docstrings, simplifiable code. Produces a score out of 10.
Bandit	Security guard	Common security flaws: eval(), shell execution (os.system), weak hashes (MD5), insecure random, hard-coded secrets, silent try/except/pass. Each finding has a severity and a confidence.
Flake8	Style checker	PEP 8 formatting and simple errors (via pycodestyle, pyflakes, mccabe): line length, whitespace, unused imports/variables, missing end-of-file newline.

Environment: Python 3.12, Pylint 4.1.3, Bandit 1.9.4, Flake8 7.5.0 (virtual environment).

2. Issues Identified by the Tools (Before Fixing)

Tool	Result before fixing
Pylint	Score 4.81/10 (25 messages)
Bandit	6 issues: 2 High, 1 Medium, 3 Low
Flake8	9 issues (F401, E501 x3, E722, F841 x2, E711, W292)

```
(venv) C:\Users\Samiksha\Desktop\College\Study materials\Sem 5\SE\LAB\Lab5\L5_48_gym_membership_system>python gym_membership_system.py
Is M01 active: True
Renewal Fee: 510.0
Member Hash: 9d442eeb170e62765efa683c5b827bbc
Locker PIN: 8544
Roster exported to: gym_roster.txt
Active count: 3
Portal secret: GYM_CLOUD_PORTAL_SECRET_2026
```

```
(venv) C:\Users\Samiksha\Desktop\College\Study materials\Sem 5\SE\LAB\Lab5\L5_48_gym_membership_system>pylint gym_membership_system.py > before/
pylint_report.txt
```

```
(venv) C:\Users\Samiksha\Desktop\College\Study materials\Sem 5\SE\LAB\Lab5\L5_48_gym_membership_system>bandit -r gym_membership_system.py > befo
re/bandit_report.txt
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.15
```

```
(venv) C:\Users\Samiksha\Desktop\College\Study materials\Sem 5\SE\LAB\Lab5\L5_48_gym_membership_system>flake8 gym_membership_system.py > before/
flake8_report.txt
```

3. Issue Identification Table

Line numbers refer to the original file. Ordered from High to Low severity. Fixes were committed in three separate commits (Bandit, Pylint, Flake8).

#	Issue	Type	Line(s)	Description	Fix Approach
1	Shell command injection (Bandit B605, High)	Security	58	os.system("echo ... " + filename) builds a shell command from a variable, so a filename like x; rm -rf ~ would execute. The shell isn't needed at all.	Removed os.system; replaced with print(...).
2	Weak hash MD5 (Bandit B324, High)	Security	47	hashlib.md5 is cryptographically broken (collisions). Unsafe if the hash is ever used for identity/integrity.	Switched to hashlib.sha256.
3	Use of eval (Bandit B307 / Pylint W0123, Medium)	Security	42	eval(discount_expr) runs arbitrary code from the caller (remote code execution if the string is user-supplied).	Removed eval. Function now takes a numeric discount (0.15 = 15% off), validates 0–1, returns fee * (1 - discount).
4	Hard-coded secret (Bandit B105, Low)	Security	70	API secret stored in source code, so it lives in git history for everyone with repo access.	Read from env var GYM_API_SECRET via os.environ.get.
5	Secret printed to console	Security (not tool-flagged)	79	Program prints the portal secret to stdout/logs.	Print only whether it is configured (True/False).
6	Insecure random for PIN (Bandit B311, Low)	Security	51	random is predictable (Mersenne Twister); not suitable for PINs/credentials.	Used secrets.randbelow(9000) + 1000; removed unused random import.
7	try / except / pass (Bandit B110, Low)	Security/Bug	26-27	Silently swallows every error; caller can't tell if cancellation worked.	Catch only KeyError; function returns True/False.
8	Bare except (Pylint W0702, Flake8 E722)	Bug	26	Catches KeyboardInterrupt/SystemExit and hides real bugs.	except KeyError: (same change as #7).

#	Issue	Type	Line(s)	Description	Fix Approach
9	Mutable default argument (Pylint W0102)	Bug	15	member_log=[] is created once and shared across all calls.	Default None; fall back to a clearly named module-level activity_log.
10	File opened without with / encoding (Pylint R1732, W1514)	Bug/Quality	55-57	File leaks if write raises; encoding depends on OS.	with open(..., encoding="utf-8"); also write valid JSON instead of str(dict).
11	== None comparison (Pylint C0121, Flake8 E711)	Style/Bug	32	Equality can be overridden; None is a singleton.	Use is None (simplified to member is not None and ...).
12	Redundant if/else returning booleans (R1703, R1705)	Quality	34-37	Four lines to return a boolean expression.	return member is not None and member["months_left"] > 0.
13	Unused variables (W0612, Flake8 F841)	Quality	31, 41, 63	locker_deposit, base_fee (inside eval), loop var m never used.	Removed locker_deposit; base_fee now genuinely used; loop rewritten with sum(...) over .values().
14	Shadowing global members (W0621)	Bug-prone	61	Parameter name hides the module-level dict.	Renamed parameter to roster.
15	Non-snake_case names (C0103)	Style	15, 23, 30, 40	registerMember, cancelMembership, checkMembershipStatus, calculateRenewalRate.	Renamed to register_member, cancel_membership, check_membership_status, calculate_renewal_rate; callers updated.
16	Missing docstrings (C0116)	Style	15,23,30,40,46,50,54,61,69	9 functions undocumented.	Added one-line docstrings.
17	Old-style % formatting (C0209)	Style	19	% string formatting.	f-string.
18	Unused import math (Pylint W0611, Flake8 F401)	Style	6	Dead import.	Removed.
19	Lines > 79 chars (Flake8 E501)	Style	10, 11, 18	Three long lines (80, 83, 93 chars).	Wrapped dicts across lines.
20	No newline at EOF (Pylint C0304, Flake8 W292)	Style	82	File ends without newline.	Added final newline.
21	main() runs on import (not tool-flagged)	Design	82	Importing the module executes the demo.	Wrapped in if __name__ == "__main__":.

Commits

Commit	Message
1 (Bandit)	Fix Bandit issues: remove eval/os.system, use SHA-256 and secrets, move secret to env var
2 (Pylint)	Fix Pylint issues: snake_case names, docstrings, mutable default, with-open, simplify logic
3 (Flake8)	Fix Flake8 issues: remove unused import, wrap long lines

4. Before-and-After Tool Outputs

4.1 before/pylint_report.txt

```
************* Module gym_membership_system
gym_membership_system.py:82:0: C0304: Final newline missing (missing-final-newline)
gym_membership_system.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:15:0: C0103: Function name "registerMember" doesn't conform to snake_case naming style (invalid-name)
gym_membership_system.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
gym_membership_system.py:19:22: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
gym_membership_system.py:23:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:23:0: C0103: Function name "cancelMembership" doesn't conform to snake_case naming style (invalid-name)
gym_membership_system.py:26:4: W0702: No exception type(s) specified (bare-except)
gym_membership_system.py:30:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:30:0: C0103: Function name "checkMembershipStatus" doesn't conform to snake_case naming style (invalid-name)
gym_membership_system.py:32:7: C0121: Comparison 'members.get(m_id) == None' should be 'members.get(m_id) is None' (singleton-comparison)
gym_membership_system.py:34:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
gym_membership_system.py:34:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
gym_membership_system.py:31:4: W0612: Unused variable 'locker_deposit' (unused-variable)
gym_membership_system.py:40:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:40:0: C0103: Function name "calculateRenewalRate" doesn't conform to snake_case naming style (invalid-name)
gym_membership_system.py:42:17: W0123: Use of eval (eval-used)
gym_membership_system.py:41:4: W0612: Unused variable 'base_fee' (unused-variable)
gym_membership_system.py:46:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:50:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:54:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:55:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
gym_membership_system.py:55:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
gym_membership_system.py:61:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:61:23: W0621: Redefining name 'members' from outer scope (line 8) (redefined-outer-name)
gym_membership_system.py:63:8: W0612: Unused variable 'm' (unused-variable)
gym_membership_system.py:69:0: C0116: Missing function or method docstring (missing-function-docstring)
gym_membership_system.py:6:0: W0611: Unused import math (unused-import)

-------------------------------------------------------------------
Your code has been rated at 4.81/10 (previous run: 4.81/10, +0.00)
```

4.2 before/bandit_report.txt

```
Run started:2026-10-30 03:39:59.402516+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\gym_membership_system.py:26:4
25              del members[m_id]
26          except:
27              pass
28

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\gym_membership_system.py:42:17
41          base_fee = members[m_id]["fee"]
42          final_rate = eval(discount_expr)
43          return final_rate

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\gym_membership_system.py:47:11
46      def generate_member_hash(m_id):
47          return hashlib.md5(m_id.encode()).hexdigest()
48

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
```

```
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\gym_membership_system.py:58:4
57          f.close()
58          os.system("echo Roster exported to: " + filename)
59

--------------------------------------------------
>> Issue: [B105:hardcoded_password_string] Possible hardcoded password: 'GYM_CLOUD_PORTAL_SECRET_2026'
   Severity: Low   Confidence: Medium
   CWE: CWE-259 (https://cwe.mitre.org/data/definitions/259.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html
   Location: .\gym_membership_system.py:70:21
69      def main():
70          gym_api_secret = "GYM_CLOUD_PORTAL_SECRET_2026"
71          registerMember("M04", "Diana", "Gold", 3)

--------------------------------------------------

Code scanned:
        Total lines of code: 60
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 3
                Medium: 1
                High: 2
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 1
                High: 5
Files skipped (0):
```

4.3 before/flake8_report.txt

```
gym_membership_system.py:6:1: F401 'math' imported but unused
gym_membership_system.py:10:80: E501 line too long (80 > 79 characters)
gym_membership_system.py:11:80: E501 line too long (83 > 79 characters)
gym_membership_system.py:18:80: E501 line too long (93 > 79 characters)
gym_membership_system.py:26:5: E722 do not use bare 'except'
gym_membership_system.py:31:5: F841 local variable 'locker_deposit' is assigned to but never used
gym_membership_system.py:32:26: E711 comparison to None should be 'if cond is None:'
gym_membership_system.py:41:5: F841 local variable 'base_fee' is assigned to but never used
gym_membership_system.py:82:7: W292 no newline at end of file
```

4.4 after/pylint_report.txt

```

 --------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)
```

4.5 after/bandit_report.txt

```
Run started:2026-10-30 13:17:26.037198+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 76
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

4.6 after/flake8_report.txt

5. Results After Fixing

5.1 Pylint (after): 10.00/10

```
(venv) C:\Users\Samiksha\Desktop\College\Study materials\Sem 5\SE\LAB\Lab5\L5_48_gym_membership_system>pylint gym_membership_system.py

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)
```

5.2 Bandit (after): no issues

```
(venv) C:\Users\Samiksha\Desktop\College\Study materials\Sem 5\SE\LAB\Lab5\L5_48_gym_membership_system>bandit -r gym_membership_system.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.15
Run started:2026-10-30 13:56:16.967359+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 76
        Total lines skipped (#nosec): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

5.3 Flake8 (after): no output

```
(venv) C:\Users\Samiksha\Desktop\College\Study materials\Sem 5\SE\LAB\Lab5\L5_48_gym_membership_system>flake8 gym_membership_system.py
```

5.4 Program still runs correctly

```
(venv) C:\Users\Samiksha\Desktop\College\Study materials\Sem 5\SE\LAB\Lab5\L5_48_gym_membership_system>python gym_membership_system.py
Is M01 active: True
Renewal Fee: 510.0
Member Hash: d968fce424f6218db2d2f8e1f407ff35150aebc0ecb10b29718d0db4359b05e3
Locker PIN: 9452
Roster exported to: gym_roster.txt
Active count: 3
Portal secret configured: False
```